

FIDO2 and WebAuthn: Ensuring Secure User Authentication

In today's digital landscape, securing online identities is more crucial than ever. Traditional passwords are no longer sufficient to protect sensitive information, which is where advanced passwordless authentication mechanisms like FIDO2 and WebAuthn come into play. These technologies offer a powerful solution for secure user authentication in a browser-based environment.



FIDO2, combined with WebAuthn, uses a challenge-response mechanism to authenticate users. This process involves a series of cryptographic requests and responses, ensuring that only the rightful users can access their account. Here's a simplified look at how this works.

A user signs up on a web scanner and a security key, such as a USB device or a biometric scanner, and enters a PIN for verification. This setup process ensures that only the user can authenticate himself/herself in the future. This mechanism is not just limited to personal accounts but is also integrated into enterprise solutions. For instance, Microsoft's cloud services, including Active Directory and Entra, utilise security

keys as a secure method for users to sign in. Microsoft Entra is a cloud based identity and access management (IAM) solution for an organisation. It keeps a record of the roles and responsibilities of its members with the help of their ID known as Entra ID.

How data is managed

All information related to Entra ID is securely stored in Microsoft Graph, a platform that requires Graph API calls to perform various operations. Graph API is an HTTP-based API that apps can use to programmatically query data and perform a wide variety of other tasks. Typically, these